Lab – Desarrollo de Políticas y Procedimientos de Ciberseguridad

Información sobre el laboratorio: Laboratorio del curso Administración de Amenazas Cibernéticas [Cisco-Fundae]

Contenido

Introducción: 2

Parte 1: Revisión del escenario 3

Parte 2: Revisión y priorización de los resultados de la auditoría 3

Parte 3: Desarrollo de Documentos de Políticas 11

Paso 2: Creación de un procedimiento 15

Parte 4: Desarrollo de un Plan para Difundir y Evaluar Políticas 27

Introducción:

ACME Healthcare es una empresa de servicios de salud que administra más de 25 centros médicos, incluidos atención para pacientes, diagnósticos, atención ambulatoria y atención de emergencia. La organización ha experimentado varias violaciones de datos en los últimos cinco años. Estas violaciones de datos han costado financieramente a la organización y han dañado su reputación.

El equipo de liderazgo ejecutivo contrató recientemente a un nuevo director de seguridad de la información (CISO). El nuevo CISO ha traído a uno de los principales equipos de penetración de ciberseguridad para realizar una auditoría de seguridad completa en toda la organización. Este contratista independiente realizó la auditoría y descubrió las siguientes vulnerabilidades:

1) Se identificaron varias cuentas de empleados que ya no trabajan en ACME.

2) Varias cuentas de usuario permitieron privilegios no autorizados y de más nivel. Estas cuentas accedían a sistemas e información sin autorización formal.

3) Varios dispositivos y sistemas permitieron el acceso remoto no seguro.

4) El 40% de todas las contraseñas de la organización auditadas se descifraron en 6 horas.

5) El vencimiento de la contraseña no estaba estandarizado.

6) Los archivos confidenciales se encontraron sin cifrar en los dispositivos de los usuarios.

7) Varios puntos de acceso inalámbrico utilizaron WEP para el cifrado y la autenticación.

8) La evidencia indica que se envió correo electrónico confidencial desde y hacia los hogares de los empleados y los dispositivos móviles sin cifrado.

9) Los registros de detección de intrusiones se revisaban y analizaban con poca frecuencia.

10) Los empleados utilizaron dispositivos con datos confidenciales de la empresa para uso privado.

11) Los dispositivos de los empleados quedaban desatendidos y los empleados fallaban en cerrar sesión en la red y los sistemas de datos de la empresa.

12) Se realizaron configuraciones y actualizaciones de dispositivos inconsistentes.

13) Se establecieron varias reglas de firewall para permitir todo el tráfico, a menos que se deniegue específicamente.

14) Los servidores de la empresa no se actualizaron con los últimos parches.

15) El servidor web de la intranet permitió a los usuarios cambiar su información personal, incluida la información de contacto.

Parte 1: Revisión del escenario

Síntesis sobre los niveles y tipos de políticas de seguridad:

Nivel o tipo	Finalidad	Ejemplo
Política general o de alto nivel	Define el compromiso de la dirección, los objetivos y las responsabilidades de seguridad.	Política corporativa de seguridad de la información.
Políticas específicas	Establecen reglas para áreas concretas de seguridad.	Política de control de acceso, contraseñas o uso aceptable.
Procedimientos e instrucciones	Explican cómo ejecutar los controles de forma operativa.	Procedimiento para dar de baja una cuenta o instalar parches.
Estándares de seguridad	Fijan requisitos técnicos mínimos que deben cumplirse.	Configuración mínima de firewall o cifrado obligatorio.

Si bien la terminología y la jerarquía exactas pueden variar entre organizaciones. La idea fundamental, independientemente del contexto, es que las políticas establecen qué debe cumplirse, los estándares concretan qué requisitos son obligatorios y los procedimientos explican cómo hacerlo.

Parte 2: Revisión y priorización de los resultados de la auditoría

a. Investigue los tipos de vulnerabilidades enumerados para determinar cuáles representan la mayor amenaza.

En el contexto de este laboratorio y para resolver esta actividad, analizaremos las 15 deficiencias de seguridad detectadas en ACME, determinaremos qué vulnerabilidades representan un mayor riesgo y se establecerá un orden de prioridad para corregirlas.

Para determinar la prioridad se tendrán en cuenta los siguientes factores:

- Impacto.
- Probabilidad.
- Alcance.
- Urgencia.

Obviamente, no todas las deficiencias detectadas tienen el mismo nivel de gravedad. Por ejemplo, una cuenta con privilegios administrativos no autorizados puede permitir comprometer numerosos sistemas, mientras que una política de caducidad de contraseñas no estandarizada requiere analizarse junto con el resto de los controles de autenticación.

A continuación, se realiza una evaluación razonada de los hallazgos:

Nº	Vulnerabilidad	Impacto	Probab.	Alcance	Urgen
1	Cuentas de exempleados activas	A	M	M	A
2	Privilegios no autorizados o excesivos	A	A	A	A
3	Acceso remoto no seguro	A	A	M	A
4	40 % de contraseñas descifradas en seis horas	A	A	A	A
5	Caducidad de contraseñas no estandarizada	M	M	A	M
6	Archivos confidenciales sin cifrar	A	A	M	A
7	Puntos de acceso Wi-Fi con WEP	A	A	M	A
8	Correo confidencial sin cifrar	A	M	M	A
9	Registros de intrusión revisados con poca frecuencia	A	M	A	A
10	Uso privado de dispositivos con datos corporativos	A	M	M	M
11	Equipos desatendidos y sesiones abiertas	A	M	M	A
12	Configuraciones y actualizaciones inconsistentes	A	M	A	A
13	Firewall que permite todo salvo lo denegado	A	A	A	A
14	Servidores sin los últimos parches	A	A	A	A
15	Modificación de datos personales en la intranet	M	M	M	M

Leyenda	
A	Alto
M	Medio
B	Bajo

A continuación, se muestra una justificación detallada e individual para cada uno de los hallazgos detectados:

1. Cuentas de exempleados activas

- Impacto alto: una cuenta abandonada puede utilizarse para acceder a información corporativa.

- Probabilidad media: el acceso depende de que la cuenta siga habilitada y de que puedan obtenerse sus credenciales.
- Alcance medio: afecta a varias cuentas, aunque no necesariamente a toda la organización.
- Urgencia alta: las cuentas deben desactivarse inmediatamente cuando ya no sean necesarias.

2. Privilegios no autorizados o excesivos

- Impacto alto: permite consultar y/o modificar información y ejecutar acciones fuera de las funciones autorizadas.
- Probabilidad alta: la auditoría ya ha confirmado que existen cuentas con privilegios inadecuados.
- Alcance alto: varias cuentas pueden acceder a sistemas e información, con posible repercusión en recursos compartidos.
- Urgencia alta: hay que revisar y retirar los permisos indebidos sin demora.

3. Acceso remoto no seguro

- Impacto alto: un atacante podría entrar en sistemas internos desde fuera de la organización.
- Probabilidad alta: existen dispositivos y sistemas que permiten conexiones remotas inseguras.
- Alcance medio: el hallazgo afecta a varios dispositivos y sistemas, pero se desconoce cuántos servicios internos son accesibles.
- Urgencia alta: hay que restringir o asegurar las conexiones remotas cuanto antes.

4. Contraseñas descifradas en seis horas

- Impacto alto: las credenciales recuperadas podrían utilizarse para suplantar usuarios y acceder a sistemas.
- Probabilidad alta: el resultado de la auditoría demuestra que una proporción considerable de las contraseñas pudo descifrarse rápidamente.
- Alcance alto: el 40 % de las contraseñas auditadas está afectado, aunque no se conoce el tamaño de la muestra.
- Urgencia alta: es necesario restablecer las credenciales vulnerables y revisar los controles de autenticación.

5. Caducidad de contraseñas no estandarizada

- Impacto medio: la falta de criterios uniformes puede generar prácticas inconsistentes, pero no demuestra por sí sola que las contraseñas sean débiles.
- Probabilidad media: el riesgo depende de la calidad de las contraseñas, la autenticación multifactor y los controles de detección.
- Alcance alto: una política organizativa inconsistente puede afectar a muchos usuarios.
- Urgencia media: conviene normalizar la política y establecer cambios de contraseña cuando existan indicios de compromiso, sin asumir que la caducidad periódica obligatoria siempre mejora la seguridad.

6. Archivos confidenciales sin cifrar

- Impacto alto: la pérdida o el robo de un dispositivo puede exponer información sensible.
- Probabilidad alta: los archivos están almacenados sin una protección criptográfica adecuada.
- Alcance medio: se han identificado archivos en dispositivos de usuarios, pero se desconoce cuántos y qué volumen de datos contienen.
- Urgencia alta: debe implantarse el cifrado y protegerse la información expuesta.

7. Puntos de acceso Wi-Fi con WEP

- Impacto alto: un atacante podría comprometer la confidencialidad de las comunicaciones inalámbricas y obtener acceso a la red.
- Probabilidad alta: WEP es un mecanismo obsoleto con debilidades criptográficas conocidas.
- Alcance medio: hay varios puntos de acceso afectados, aunque se desconoce la cobertura de cada uno.
- Urgencia alta: debe sustituirse por WPA2-AES o WPA3, según la compatibilidad y los requisitos de seguridad.

8. Correo confidencial sin cifrar

- Impacto alto: puede producir la divulgación de información confidencial durante su transmisión.

- Probabilidad media: la exposición está documentada, pero no se ha confirmado que un tercero haya interceptado los mensajes.
- Alcance medio: intervienen empleados, hogares y dispositivos móviles.
- Urgencia alta: hay que proteger las comunicaciones con mecanismos de cifrado adecuados y revisar las vías de envío.

9. Registros de intrusión revisados con poca frecuencia

- Impacto alto: un ataque puede permanecer sin detectar y provocar mayores daños.
- Probabilidad media: la debilidad de supervisión está confirmada, pero no se ha demostrado que exista un ataque activo.
- Alcance alto: una detección tardía puede afectar a numerosos sistemas de la organización.
- Urgencia alta: deben establecerse revisiones periódicas y alertas oportunas para los eventos críticos.

10. Uso privado de dispositivos con datos corporativos

- Impacto alto: el uso personal puede facilitar infecciones de malware o fugas de información.
- Probabilidad media: aumenta la exposición, aunque no demuestra que se haya producido un incidente.
- Alcance medio: afecta a los dispositivos y empleados que combinan ambos usos.
- Urgencia media: deben definirse reglas de uso aceptable y controles para separar los datos personales y corporativos.

11. Equipos desatendidos y sesiones abiertas

- Impacto alto: otra persona podría utilizar una sesión ya autenticada para acceder a datos o ejecutar acciones.
- Probabilidad media: el riesgo depende de la posibilidad de que alguien acceda al dispositivo mientras está desatendido.
- Alcance medio: afecta a los equipos y sesiones donde se produce esta conducta.
- Urgencia alta: deben implantarse bloqueos automáticos, cierre de sesión cuando corresponda y formación a los empleados.

12. Configuraciones y actualizaciones inconsistentes

- Impacto alto: los dispositivos mal configurados pueden exponer servicios o debilitar controles de seguridad.
- Probabilidad media: la inconsistencia aumenta el riesgo, pero no se especifica qué configuraciones son vulnerables.
- Alcance alto: el hallazgo menciona dispositivos y sistemas en plural y puede reflejar un problema de gestión general.
- Urgencia alta: es necesario establecer configuraciones de referencia y verificar su cumplimiento.

13. Firewall que permite todo salvo lo denegado

- Impacto alto: el tráfico innecesario puede facilitar conexiones no autorizadas y el acceso a servicios expuestos.
- Probabilidad alta: la configuración permisiva está confirmada y amplía la superficie de ataque.
- Alcance alto: las reglas de firewall pueden afectar a numerosos sistemas y segmentos de red.
- Urgencia alta: hay que revisar las reglas y permitir únicamente el tráfico expresamente autorizado.

14. Servidores sin los últimos parches

- Impacto alto: una vulnerabilidad explotable puede comprometer la confidencialidad, integridad o disponibilidad de los servicios.
- Probabilidad alta: la falta de actualizaciones está confirmada, aunque debe verificarse qué vulnerabilidades concretas están presentes.
- Alcance alto: los servidores pueden soportar aplicaciones y servicios compartidos por muchos usuarios.
- Urgencia alta: hay que identificar las vulnerabilidades, priorizar los parches críticos y aplicarlos de forma controlada.

15. Modificación de información personal en la intranet

- Impacto medio: permitir modificar datos personales es una función legítima en muchos sistemas; el riesgo aparece si falta autorización o validación.
- Probabilidad media: el hallazgo no demuestra por sí mismo que exista una vulnerabilidad explotable.

- Alcance medio: afecta a usuarios de la intranet y a los datos que pueden modificar.
- Urgencia media: deben comprobarse los permisos, la validación de entradas y los registros de cambios antes de determinar la gravedad real.

b. Según su investigación, enumere los cinco hallazgos principales de auditoría de seguridad que ACME debe abordar, comenzando por la mayor vulnerabilidad.

Nº	Hallazgo	Nivel	Justificación
1	Privilegios excesivos	Crítica	Hay accesos no autorizados confirmados a sistemas e información.
2	Firewall permisivo	Crítica	Puede exponer numerosos servicios y ampliar la superficie de ataque.
3	Servidores sin parches	Crítica	Es necesario comprobar y corregir vulnerabilidades conocidas en los sistemas.
4	Contraseñas descifradas	Crítica	El resultado de la auditoría demuestra una debilidad significativa de las credenciales.
5	Archivos confidenciales sin cifrar	Crítica	Existe riesgo de divulgación de información sensible ante la pérdida o el compromiso de dispositivos.

c. Registre sus clasificaciones en una Tabla de Clasificación de Vulnerabilidades, como la que se muestra a continuación. Enumera las *Vulnerabilidades,* la *Política Recomendada* para mitigar esta vulnerabilidad y su *Justificación* para la clasificación que determinó.

Tabla de Clasificación de Vulnerabilidades			
Nº	**Vulnerabilidad**	**Política recomendada**	**Justificación de la clasificación**
1	**Privilegios excesivos**	Política de control de acceso y gestión de identidades.	Prioridad crítica. El impacto es alto porque los usuarios pueden acceder a sistemas e información sin autorización. La probabilidad de abuso es significativa, ya que la auditoría confirma que existen permisos indebidos. El alcance puede incluir varios sistemas y usuarios. La urgencia es alta porque deben retirarse los privilegios innecesarios y aplicarse el principio de mínimo privilegio.

2	**Firewall permisivo**	Política de seguridad de redes y gestión de firewalls.	Prioridad crítica. La configuración permisiva puede exponer servicios y facilitar conexiones no autorizadas. La probabilidad de explotación aumenta si los servicios expuestos presentan otras debilidades. El alcance puede abarcar múltiples equipos y segmentos de red. La urgencia es alta porque deben revisarse las reglas y bloquearse las comunicaciones no autorizadas.
3	**Servidores sin parches**	Política de gestión de vulnerabilidades y actualizaciones de seguridad.	Prioridad crítica. Los servidores desactualizados pueden contener vulnerabilidades conocidas que permitan comprometer datos o interrumpir servicios. La probabilidad depende de las vulnerabilidades presentes y de su exposición. El alcance puede ser elevado si los servidores soportan servicios corporativos esenciales. La urgencia es alta hasta verificar y corregir las vulnerabilidades relevantes.
4	**Contraseñas descifradas**	Política de autenticación y gestión de credenciales.	Prioridad crítica. El resultado demuestra una debilidad significativa en las contraseñas analizadas. Las credenciales recuperadas podrían utilizarse para suplantar usuarios y acceder a recursos corporativos. El porcentaje afectado indica un problema importante, aunque se desconoce el tamaño de la muestra. La urgencia es alta: deben restablecerse las credenciales vulnerables y reforzarse la autenticación, incluyendo MFA.

5	**Archivos confidenciales sin cifrar**	Política de clasificación, protección y cifrado de la información.	Prioridad crítica. La información puede quedar expuesta si un dispositivo se pierde, es robado o resulta comprometido. La probabilidad depende de las circunstancias de exposición, pero la ausencia de cifrado aumenta las consecuencias potenciales. El alcance depende del número de dispositivos y archivos afectados. La urgencia es alta porque deben protegerse los datos almacenados y gestionarse adecuadamente las claves de cifrado.

Conclusión: En primer lugar, ACME debería abordar los privilegios excesivos, las reglas permisivas del firewall, las vulnerabilidades de los servidores, las contraseñas débiles y la falta de cifrado de archivos confidenciales.

Este orden es únicamente una propuesta inicial de priorización ya que debe confirmarse con una evaluación técnica de la exposición real y de las vulnerabilidades concretas.

Parte 3: Desarrollo de Documentos de Políticas

a. Elija una vulnerabilidad en la tabla para desarrollar una política de seguridad.

Para esta demostración escogemos la vulnerabilidad n.º 2: privilegios no autorizados o excesivos.

Entendemos se trata de una buena elección para desarrollar una política formal porque permite definir responsabilidades, autorizaciones, revisiones periódicas y medidas correctivas concretas manteniendo el carácter demostrativo de este documento.

b. Utilice las Plantillas de Políticas de Seguridad de la Información para desarrollar una política de seguridad específica para ACME Healthcare que aborde la vulnerabilidad elegida.

ACME HEALTHCARE

Política de Gestión de Accesos

Última actualización	Octubre de 2026
Versión	1.0
Responsable de la política	Responsable de Seguridad de la Información
Aprobación	Dirección de ACME Healthcare

1. Propósito

La Política de Gestión de Accesos de ACME Healthcare tiene como objetivo principal dotar a la corporación de un marco integral para controlar y gestionar el acceso de los usuarios a los sistemas, aplicaciones y recursos de datos de la organización.

Esta política establece directrices para conceder, revisar y revocar privilegios de acceso, garantizando que cada usuario disponga del nivel de acceso adecuado según sus funciones y responsabilidades. Su finalidad es reducir el riesgo de accesos no autorizados, filtraciones de datos y amenazas internas mediante prácticas eficaces de gestión de accesos.

ACME Healthcare aplicará mecanismos sólidos de autenticación, controles de acceso basados en roles y revisiones periódicas de permisos para garantizar que únicamente las personas autorizadas puedan acceder a la información sensible. Se protegerán especialmente la confidencialidad e integridad de los datos sanitarios y se promoverá el cumplimiento de los requisitos legales y normativos aplicables.

La gestión de accesos constituye una medida esencial para reforzar la ciberseguridad de la organización y proteger la confianza de pacientes, empleados y demás partes interesadas.

2. Alcance

Esta política se aplica a todos los empleados, profesionales sanitarios, contratistas, proveedores y terceros que dispongan de acceso a los sistemas, aplicaciones, redes o recursos de información de ACME Healthcare.

Abarca todas las cuentas de usuario y credenciales utilizadas para autenticar y autorizar el acceso a la infraestructura tecnológica, incluidos los sistemas de gestión de historiales clínicos electrónicos y demás recursos que contengan información sanitaria o datos personales.

La política establece los requisitos para la creación, modificación y eliminación de cuentas; la asignación de permisos basada en roles; la segregación de funciones; la gestión de contraseñas y sesiones; y la revocación de accesos.

Todos los accesos deberán ajustarse a las funciones profesionales del usuario y a los principios de mínimo privilegio y necesidad de conocer. El cumplimiento es obligatorio. Cualquier excepción deberá documentarse, justificarse y recibir la aprobación de la autoridad designada por ACME Healthcare para la gestión de accesos y la seguridad de la información.

3. Salvaguardas

Para cumplir la misión de ACME Healthcare y los objetivos de esta política de ciberseguridad, la organización deberá aplicar las siguientes salvaguardas:

AM-01. Definición de funciones y responsabilidades.
Establecer y documentar un proceso para definir las funciones y responsabilidades de cada miembro de la organización, de forma que los permisos asignados respondan a sus necesidades profesionales.

AM-02. Segregación de funciones.
Garantizar que la definición documentada de funciones y responsabilidades tenga en cuenta la segregación de funciones para evitar que una misma persona acumule permisos incompatibles que puedan facilitar errores, fraudes o accesos indebidos.

AM-03. Listas de control de acceso documentadas.
Mantener listas de control de acceso (ACL) documentadas para cada sistema informático y aplicación empresarial de ACME Healthcare.

AM-04. Correspondencia entre roles y permisos.
Garantizar que las ACL de los sistemas y aplicaciones se basen en los roles y responsabilidades definidos y aprobados por la organización.

AM-05. Control de acceso a objetos del sistema.
Mantener las ACL aplicadas a los objetos de los sistemas informáticos de acuerdo con la documentación aprobada, los roles definidos y el principio de mínimo privilegio.

AM-06. Control de acceso a funciones del sistema.
Mantener las ACL de las funciones de los sistemas informáticos de acuerdo con la documentación aprobada, los roles definidos y el principio de mínimo privilegio.

AM-07. Control de acceso a repositorios de código.
Mantener las ACL de los repositorios de código de acuerdo con la documentación

aprobada, los roles definidos y el principio de mínimo privilegio, cuando estos recursos sean utilizados por la organización.

AM-08. Protección de datos almacenados.
Garantizar, mediante los controles de acceso y las medidas técnicas correspondientes, que los sistemas de ACME Healthcare protejan los datos almacenados mediante cifrado cuando resulte necesario según su clasificación y los requisitos de seguridad aplicables.

AM-09. Protección de datos en tránsito.
Garantizar que los sistemas y aplicaciones utilicen mecanismos de cifrado adecuados para proteger los datos durante su transmisión, de acuerdo con su sensibilidad y los requisitos de seguridad aplicables.

AM-10. Revisión periódica de las ACL.
Establecer un proceso para revisar periódicamente las ACL implementadas en los sistemas y aplicaciones, comprobar que los permisos continúan siendo necesarios y corregir las desviaciones detectadas.

AM-11. Revisión de la documentación de accesos.
Establecer un proceso para revisar periódicamente la documentación de las ACL y mantenerla actualizada respecto a los sistemas, aplicaciones y permisos existentes.

AM-12. Revisión de grupos y roles.
Establecer un proceso para revisar periódicamente la pertenencia de los usuarios a grupos y roles utilizados por las ACL, retirando los permisos excesivos o que ya no estén justificados por sus funciones.

AM-13. Registro y alertas de cambios.
Garantizar que los sistemas de información registren y generen alertas sobre los cambios en la pertenencia a grupos o roles y sobre las modificaciones de las ACL configuradas. Estos registros deberán protegerse frente a alteraciones no autorizadas y revisarse según su criticidad.

4. Sanciones por incumplimiento de la política

El incumplimiento de esta política podrá dar lugar a medidas disciplinarias conforme a los procedimientos de Recursos Humanos y a las normas internas de ACME Healthcare.

Las consecuencias podrán incluir formación correctiva obligatoria, advertencias formales, suspensión temporal de determinados privilegios de acceso y, en los casos graves, la finalización de la relación laboral o contractual, de acuerdo con la legislación aplicable.

Cuando una infracción constituya una actividad ilegal, podrán aplicarse las consecuencias legales correspondientes.

Las medidas se aplicarán de manera coherente e imparcial, teniendo en cuenta la gravedad del incumplimiento, sus consecuencias, la intencionalidad y las circunstancias del caso.

5. Aprobación y revisión

La Dirección de ACME Healthcare será responsable de aprobar esta política. El Responsable de Seguridad de la Información supervisará su cumplimiento y propondrá las actualizaciones necesarias.

La política se revisará al menos una vez al año y siempre que se produzcan cambios significativos en los sistemas, los riesgos de seguridad o los requisitos legales aplicables.

Aprobado por: Dirección de ACME Healthcare
Firma: _____
Fecha de aprobación: _____

Paso 2: Creación de un procedimiento

a. Cree un conjunto de instrucciones paso a paso que respalde su política de seguridad de la información. Vaya a Política de Seguridad de la Información: Guía de Desarrollo y Tedacción Técnica para las Políticas de Seguridad de TI en Cinco Pasos Sencillos para obtener instrucciones y orientación.

ACME HEALTHCARE

Procedimiento de alta, modificación, revisión y revocación de accesos

Identificador	ACME-SEC-PROC-001
Versión	1.0
Política relacionada	ACME-SEC-POL-001 Política de Gestión de Accesos
Responsable	Responsable de Seguridad de la Información
Estado:	Propuesta para aprobación

1. Objetivo

Establecer un procedimiento paso a paso para garantizar que los usuarios de ACME Healthcare dispongan únicamente de los permisos necesarios para desempeñar sus funciones, evitando accesos no autorizados y privilegios excesivos.

2. Alcance

Este procedimiento se aplica al personal de TI, responsables de área, Recursos Humanos y demás personas autorizadas para solicitar, aprobar, implementar o revisar accesos a los sistemas, aplicaciones y datos de ACME Healthcare.

3. Responsabilidades

- **Recursos Humanos**: comunicar las incorporaciones, los cambios de puesto y las bajas.
- **Responsable del área**: solicitar los accesos necesarios y justificar los permisos requeridos.
- **Departamento de TI:** crear, modificar, bloquear y eliminar cuentas, así como configurar los permisos aprobados.
- **Responsable de Seguridad de la Información:** supervisar el cumplimiento, revisar las excepciones y coordinar las actuaciones correctivas.

4. Procedimiento operativo

Paso 1. Recibir la solicitud de acceso

El responsable del área deberá presentar una solicitud mediante el canal autorizado por ACME Healthcare. La solicitud incluirá:

- Nombre e identificador del usuario.
- Área y puesto de trabajo.
- Sistema o aplicación al que necesita acceder.
- Rol y permisos solicitados.
- Justificación de la necesidad de acceso.
- Fecha de inicio y, cuando corresponda, fecha de finalización.
- Identidad del responsable que autoriza la solicitud.

Las solicitudes incompletas deberán devolverse para su corrección antes de continuar.

Paso 2. Verificar la identidad y la necesidad de acceso

El Departamento de TI comprobará que la identidad del usuario está verificada y que la solicitud procede de un responsable autorizado.

Se comprobará que los permisos solicitados corresponden a las funciones del usuario y que no existen accesos incompatibles con sus responsabilidades. El acceso a historiales clínicos y otros datos sensibles deberá limitarse estrictamente a las necesidades profesionales justificadas.

Paso 3. Obtener la aprobación

El responsable del área deberá aprobar los permisos solicitados antes de su implementación.

Los privilegios administrativos o de especial sensibilidad requerirán una justificación adicional y la aprobación de la autoridad designada por ACME Healthcare.

No se concederán permisos basándose únicamente en solicitudes verbales o instrucciones sin autorización verificable, salvo que exista un procedimiento de emergencia formalmente aprobado.

Paso 4. Crear la cuenta y asignar los permisos

Una vez aprobada la solicitud, el Departamento de TI deberá:

1. Crear una cuenta individual asociada al usuario identificado.
2. Asignar el rol correspondiente según la matriz de roles y permisos aprobada.
3. Conceder únicamente los permisos necesarios para realizar sus funciones.
4. Evitar cuentas compartidas y privilegios administrativos innecesarios.
5. Configurar los mecanismos de autenticación exigidos por la política, incluida la autenticación multifactor cuando corresponda.
6. Verificar que las medidas de protección de los datos y las restricciones de acceso están aplicadas.
7. Registrar la fecha de ejecución y la persona responsable de los cambios.

La cuenta no deberá habilitarse antes de completar las autorizaciones requeridas.

Paso 5. Verificar el acceso concedido

El Departamento de TI comprobará que el usuario puede acceder a los recursos autorizados y que no puede realizar acciones fuera de sus permisos.

Cuando sea necesario, el responsable del área confirmará que el acceso permite desempeñar las funciones asignadas.

Cualquier permiso excesivo o acceso indebido detectado deberá corregirse antes de dar por finalizada la solicitud.

Paso 6. Modificar los permisos cuando cambien las funciones

Cuando un usuario cambie de puesto, departamento o responsabilidades:

1. El responsable del área comunicará el cambio mediante el canal autorizado.
2. Se revisarán los permisos existentes y los necesarios para las nuevas funciones.
3. Se retirarán los permisos que hayan dejado de ser necesarios.
4. Se solicitarán y aprobarán los permisos adicionales antes de concederlos.
5. TI implementará los cambios y registrará las actuaciones.
6. Se verificará que los permisos finales sean adecuados.

No se acumularán permisos de distintos puestos sin una justificación y aprobación expresas.

Paso 7. Revocar los accesos de usuarios que abandonen la organización

Cuando finalice la relación laboral o contractual:

1. Recursos Humanos notificará la baja al Departamento de TI por el canal establecido.
2. TI deshabilitará las cuentas y revocará los accesos en el momento definido por el procedimiento de baja, coordinándolo con la fecha efectiva de salida.
3. Se revocarán las sesiones activas, credenciales remotas, tokens y otros mecanismos de acceso que corresponda.
4. Se retirarán los permisos en los sistemas y aplicaciones afectados.
5. Se conservarán los registros necesarios conforme a las políticas de retención aplicables.
6. TI documentará la fecha, las acciones ejecutadas y el responsable de la revocación.

Si se detecta una cuenta activa de un exempleado sin justificación, se bloqueará con carácter inmediato y se investigará el motivo de su permanencia.

Paso 8. Revisar periódicamente los accesos

Los responsables de los sistemas y aplicaciones, con apoyo de TI, realizarán revisiones trimestrales de los permisos.

Durante cada revisión deberán:

1. Obtener el listado actualizado de cuentas, roles y permisos.
2. Identificar cuentas inactivas, duplicadas, huérfanas o pertenecientes a antiguos empleados.
3. Detectar privilegios excesivos y combinaciones incompatibles de permisos.
4. Confirmar con los responsables de área que cada acceso sigue siendo necesario.
5. Retirar o corregir los permisos no justificados.
6. Registrar las decisiones, los cambios realizados y las incidencias pendientes.
7. Escalar al Responsable de Seguridad de la Información cualquier anomalía relevante.

Los accesos privilegiados y las cuentas con acceso a información especialmente sensible podrán someterse a revisiones más frecuentes según el riesgo.

Paso 9. Registrar y supervisar las operaciones

TI deberá mantener evidencias de las solicitudes, aprobaciones, altas, modificaciones, revocaciones y revisiones de acceso.

Los sistemas deberán registrar los cambios de roles, grupos y listas de control de acceso cuando dispongan de esa funcionalidad. Los registros estarán protegidos contra modificaciones no autorizadas y se revisarán conforme a la criticidad de los sistemas.

Los accesos sospechosos o los privilegios indebidos se comunicarán al Responsable de Seguridad de la Información para su evaluación y, cuando proceda, para activar el procedimiento de gestión de incidentes.

Paso 10. Gestionar excepciones

Toda excepción deberá:

1. Estar documentada y justificada.
2. Identificar el riesgo y los controles compensatorios.

3. Contar con la aprobación de la autoridad designada.
4. Tener un plazo de validez definido.
5. Revisarse antes de su vencimiento.
6. Revocarse cuando deje de ser necesaria.

Las excepciones no podrán utilizarse para eludir los controles de autorización ni para mantener privilegios indefinidamente.

5. Evidencias y registros

Se conservarán, según las reglas de retención de ACME Healthcare:

- Solicitudes y aprobaciones de acceso.
- Inventario de cuentas, roles y permisos.
- Registros de altas, modificaciones y bajas.
- Evidencias de las revisiones trimestrales.
- Excepciones autorizadas y sus fechas de vencimiento.
- Incidencias detectadas y acciones correctivas.

El acceso a estos registros estará limitado al personal autorizado.

6. Comprobación del cumplimiento

El Responsable de Seguridad de la Información evaluará el cumplimiento mediante revisiones de permisos, comprobaciones de cuentas de exempleados, análisis de registros y auditorías internas.

Se considerará que una solicitud está completada cuando los permisos hayan sido aprobados, implementados, verificados y documentados. Las desviaciones deberán asignarse a un responsable y contar con una acción correctiva y una fecha de resolución.

7. Referencias

- **ACME Healthcare. *Política de Gestión de Accesos*, ACME-SEC-POL-001.**
- **SANS Institute.** Information Security Policy — A Development Guide for Large and Small Companies**.**
- **SANS Institute.** Technical Writing for IT Security Policies in Five Easy Steps**.**

Aprobado por: _____
Fecha de aprobación: _____

b. Incluya toda la información que un usuario necesitaría para configurar o completar correctamente la tarea de acuerdo con la política de seguridad.

ACME HEALTHCARE

Instrucciones para la solicitud y gestión de permisos de acceso

Identificador	ACME-SEC-INS-001
Versión	1.0
Política relacionada	ACME-SEC-POL-001 Política de Gestión de Accesos
Procedimiento relacionado	ACME-SEC-PROC-001 Procedimiento de alta, modificación, revisión y revocación de accesos
Responsable	Responsable de Seguridad de la Información
Responsable	Responsable de Seguridad de la Información
Estado	Propuesta para aprobación
Fecha	Octubre de 2026

1. Objetivo

Proporcionar instrucciones claras para que los empleados, responsables de área y personal de TI soliciten, autoricen, configuren y revisen los permisos de acceso a los sistemas y a la información de ACME Healthcare.

Estas instrucciones buscan garantizar que cada usuario disponga únicamente de los permisos necesarios para desempeñar sus funciones, especialmente cuando acceda a información clínica, sistemas de diagnóstico y otros recursos que contengan información confidencial.

2. Información necesaria para solicitar un acceso

Antes de iniciar una solicitud, el solicitante deberá disponer de la siguiente información:

- **Identificación del usuario:** nombre completo e identificador corporativo.
- **Departamento y puesto:** área en la que trabaja y funciones que desempeña.
- **Sistema o recurso:** aplicación, servidor, repositorio, dispositivo o información a la que necesita acceder.
- **Tipo de acceso:** lectura, creación, modificación, eliminación o administración, según las funciones permitidas por el sistema.

- **Rol solicitado:** perfil de permisos definido en la matriz de control de accesos de ACME Healthcare, cuando exista.
- **Justificación empresarial:** explicación de por qué necesita el acceso para realizar su trabajo.
- **Duración:** acceso permanente asociado al puesto o acceso temporal con fecha de finalización.
- **Aprobación:** responsable del área o propietario del sistema autorizado para validar la necesidad del acceso.
- **Requisitos adicionales:** autenticación multifactor (MFA), acceso remoto u otras medidas de seguridad aplicables.

Las solicitudes incompletas deberán devolverse al solicitante para su corrección. No se deben solicitar contraseñas personales ni incluirlas en formularios, correos o tickets.

3. Instrucciones para solicitar y configurar el acceso

Paso 1. Identificar el recurso necesario

Determine qué sistema o información necesita utilizar. Solicite acceso al recurso concreto y evite pedir permisos generales cuando exista un perfil específico para su función.

En el caso de información sanitaria, especifique la necesidad profesional de acceso sin incluir datos reales de pacientes en la solicitud, salvo que un proceso autorizado requiera expresamente esa información.

Paso 2. Seleccionar el rol adecuado

Seleccione el rol que corresponda a sus responsabilidades laborales. El acceso deberá seguir el principio de mínimo privilegio: conceder únicamente los permisos indispensables.

Por ejemplo, un usuario que solo necesita consultar información no debe solicitar permisos de modificación o administración. Los permisos privilegiados deben limitarse al personal autorizado y contar con una justificación específica.

Paso 3. Enviar la solicitud para su aprobación

Remita la solicitud mediante el canal corporativo de gestión de accesos que ACME Healthcare tenga establecido. Incluya todos los datos requeridos y espere la aprobación correspondiente.

No cree cuentas, modifique permisos ni intente obtener acceso por medios alternativos antes de recibir la autorización.

Paso 4. Esperar la implementación por personal autorizado

El equipo de TI o el administrador designado deberá comprobar la aprobación, asignar la cuenta individual y aplicar el rol autorizado.

Cuando corresponda, deberá habilitarse la autenticación multifactor y configurarse el acceso remoto seguro. Las cuentas compartidas deberán evitarse, y las cuentas administrativas deberán utilizarse únicamente para las tareas que requieran privilegios elevados.

Paso 5. Verificar el resultado

Una vez confirmado que el acceso está disponible, compruebe que puede realizar las tareas autorizadas y que no dispone de permisos innecesarios.

Si detecta permisos excesivos, acceso a información no relacionada con sus funciones o imposibilidad de realizar una tarea autorizada, comuníquelo al equipo de TI. No intente corregir la configuración por su cuenta si no dispone de autorización administrativa.

Paso 6. Solicitar cambios cuando cambien las funciones

Si cambia de puesto, departamento o responsabilidades, solicite la modificación de sus permisos. Los accesos anteriores que ya no sean necesarios deberán retirarse, y los nuevos permisos deberán aprobarse antes de su aplicación.

Paso 7. Comunicar la finalización de la necesidad de acceso

Cuando deje de necesitar un recurso, finalice una colaboración o termine su relación laboral con ACME Healthcare, deberá comunicarse la situación al responsable correspondiente para que se retiren los permisos. La baja de cuentas corporativas será gestionada por los responsables designados.

4. Instrucciones para responsables de área y aprobadores

Antes de aprobar una solicitud, el responsable deberá:

1. Confirmar la identidad del usuario y su relación laboral o funcional con ACME Healthcare.
2. Verificar que el acceso es necesario para sus funciones.
3. Comprobar que el rol solicitado se ajusta a la matriz de permisos aprobada.

4. Rechazar los permisos excesivos o incompatibles con las responsabilidades del usuario.
5. Exigir una justificación adicional para accesos administrativos, información clínica especialmente sensible o accesos remotos privilegiados.
6. Confirmar si el acceso debe tener una fecha de caducidad.
7. Dejar constancia de la aprobación o denegación.

La aprobación no sustituye a la validación técnica que debe realizar el equipo de TI.

5. Instrucciones para el equipo de TI

El personal autorizado para administrar los accesos deberá:

- Verificar que existe una aprobación válida antes de realizar cambios.
- Crear cuentas individuales y asignar únicamente los roles aprobados.
- Aplicar los controles de autenticación requeridos, incluida MFA cuando corresponda.
- Configurar las listas de control de acceso (ACL) según los roles y el principio de mínimo privilegio.
- Aplicar controles apropiados a los datos almacenados y transmitidos, de acuerdo con la política de seguridad.
- Registrar las altas, modificaciones, revocaciones y cambios en grupos, roles y ACL.
- Comprobar que los permisos efectivos coinciden con los autorizados.
- Retirar los permisos anteriores cuando se produzcan cambios de puesto.
- Deshabilitar o revocar los accesos cuando corresponda una baja, siguiendo los plazos y responsabilidades establecidos por ACME Healthcare.
- Escalar cualquier solicitud excepcional o conflicto de permisos al responsable competente.

6. Revisión periódica de los accesos

Los responsables designados deberán revisar los accesos al menos trimestralmente, conforme al procedimiento establecido, prestando especial atención a los sistemas que contienen información clínica y a las cuentas privilegiadas.

Durante la revisión deberán comprobar:

- Que cada cuenta pertenece a un usuario autorizado.
- Que no existen cuentas activas de exempleados.
- Que los permisos siguen siendo necesarios para las funciones actuales.
- Que no existen privilegios excesivos o incompatibles.
- Que los accesos temporales han sido retirados al finalizar su vigencia.
- Que los cambios de roles y permisos están documentados.

Las desviaciones detectadas deberán documentarse, corregirse y comunicarse según el procedimiento de gestión de incidencias de seguridad.

7. Gestión de excepciones e incidencias

Si una necesidad operativa no puede cubrirse con los roles existentes, el usuario deberá presentar una solicitud excepcional que incluya la justificación, el alcance, la duración y los riesgos identificados.

La excepción solo podrá aplicarse tras la aprobación de las personas autorizadas y la definición de controles compensatorios cuando sean necesarios. Deberá revisarse y retirarse al finalizar el plazo autorizado.

Si un usuario detecta una cuenta desconocida, permisos no autorizados o un acceso sospechoso, deberá comunicarlo inmediatamente por el canal corporativo de notificación de incidencias. No deberá investigar ni alterar registros o configuraciones sin autorización.

8. Registros y evidencias

Para demostrar el cumplimiento de estas instrucciones, ACME Healthcare conservará, conforme a sus normas de conservación documental:

- Solicitudes de acceso y sus justificaciones.
- Aprobaciones y denegaciones.
- Registros de creación, modificación y revocación de cuentas.
- Evidencias de la configuración y verificación de permisos.
- Registros de cambios en grupos, roles y ACL.
- Resultados de las revisiones periódicas.
- Excepciones aprobadas y sus fechas de expiración.

- Incidencias relacionadas con accesos no autorizados y las acciones correctivas aplicadas.

Los registros deberán protegerse frente a accesos, modificaciones o eliminaciones no autorizados.

9. Lista de comprobación para el usuario

Antes de dar por finalizada una solicitud, confirme que:

	Si	No
He identificado el sistema o recurso concreto.		
He explicado por qué necesito el acceso.		
He seleccionado el rol y los permisos mínimos necesarios.		
He indicado la duración del acceso, cuando corresponda.		
He obtenido la aprobación requerida.		
He esperado a que el personal autorizado configure el acceso.		
He comprobado que los permisos funcionan y no son excesivos.		
He comunicado cualquier anomalía detectada.		

10. Referencias

- ACME Healthcare, **Política de Gestión de Accesos**, ACME-SEC-POL-001.
- ACME Healthcare, **Procedimiento de alta, modificación, revisión y revocación de accesos**, ACME-SEC-PROC-001.
- SANS Institute, *Information Security Policy Development Guide*: https://www.sans.org/reading-room/whitepapers/policyissues/information-security-policy-development-guide-large-small-companies-1331
- SANS Institute, *Technical Writing for IT Security Policies in Five Easy Steps*: https://www.sans.org/reading-room/whitepapers/policyissues/technical-writing-security-policies-easy-steps-492

Nota de implantación: Los canales de solicitud, herramientas, responsables nominales y plazos concretos deberán completarse con los datos reales de ACME Healthcare antes de aprobar y poner en práctica estas instrucciones.

Parte 4: Desarrollo de un Plan para Difundir y Evaluar Políticas

Paso 1: Crear un plan de implementación y difusión de políticas de seguridad de la información.

a. Documentar la información requerida para crear un plan de implementación y difusión de políticas de seguridad de la información.

b. Incluya tareas y eventos específicos que ACME Healthcare utilizará para asegurarse de que todos los empleados involucrados conozcan las políticas de seguridad de la información que les concierne.

c. Incluya todos los departamentos específicos que deban participar. ACME Healthcare también debe poder evaluar si las personas tienen el conocimiento adecuado de las políticas relacionadas con sus responsabilidades laborales.

ACME HEALTHCARE

Plan de implementación, difusión y evaluación de las políticas de seguridad de la información

Código	ACME-SEC-PLAN-001
Versión	1.0
Fecha	Octubre de 2026
Responsable del plan	Responsable de Seguridad de la Información
Ámbito	Todas las instalaciones, departamentos, empleados y colaboradores autorizados de ACME Healthcare
Estado	Propuesta para aprobación por la Dirección

1. Objetivo

Establecer un plan para implementar y difundir las políticas de seguridad de la información de ACME Healthcare, asegurando que todos los empleados y colaboradores conozcan las normas que afectan a sus responsabilidades laborales y sepan aplicarlas correctamente.

El plan pretende reducir el riesgo de accesos no autorizados, pérdida o exposición de información clínica, uso indebido de cuentas, divulgación de información confidencial y otros incidentes de seguridad.

Además, establece mecanismos para evaluar la comprensión de las políticas, identificar necesidades de formación y comprobar la eficacia de las actividades realizadas.

2. Información necesaria para elaborar el plan

Antes de ponerlo en marcha, ACME Healthcare deberá recopilar y documentar la siguiente información:

1. **Inventario de políticas:** políticas aprobadas, versión vigente, fecha de entrada en vigor y responsable de cada documento.
2. **Inventario de departamentos y puestos:** áreas de la organización, funciones, responsables y perfiles de acceso a la información.
3. **Público destinatario:** empleados, personal temporal, profesionales sanitarios, personal administrativo, personal técnico, directivos y terceros con acceso autorizado.
4. **Necesidades de formación:** conocimientos previos, riesgos asociados a cada puesto y formación específica que necesita cada grupo.
5. **Canales de comunicación:** correo corporativo, intranet, plataforma de formación, reuniones de equipo, sesiones presenciales y comunicaciones de responsables de área.
6. **Recursos disponibles:** personal de formación, responsables de seguridad, presupuesto, herramientas de aprendizaje y tiempo de trabajo asignado.
7. **Calendario de implementación:** fechas de lanzamiento, sesiones formativas, evaluaciones, recordatorios y revisiones.
8. **Métodos de evaluación:** cuestionarios, ejercicios prácticos, comprobaciones de comprensión y métricas de participación y resultados.
9. **Gestión de evidencias:** registro de asistentes, aceptación de políticas, resultados de evaluaciones, formación de recuperación y acciones correctivas.
10. **Requisitos legales y organizativos:** obligaciones aplicables a la protección de datos personales y sanitarios, confidencialidad, control de acceso y conservación de registros.

La Dirección deberá aprobar el plan y asignar los recursos necesarios. El Responsable de Seguridad de la Información coordinará su ejecución y seguimiento.

3. Departamentos y responsabilidades

Departamento o función	Responsabilidades
Dirección	Aprobar las políticas, respaldar el plan, asignar recursos y revisar los resultados.
Seguridad de la Información	Coordinar la difusión, preparar los contenidos, definir los controles de conocimiento y evaluar la eficacia del plan.
Recursos Humanos	Incorporar la formación al proceso de acogida, informar de altas, cambios de puesto y bajas, y mantener registros de formación.
Tecnologías de la Información (TI)	Explicar los procedimientos técnicos de acceso, contraseñas, MFA, dispositivos, actualizaciones, acceso remoto y gestión de cuentas.
Protección de Datos / Privacidad	Formar sobre el tratamiento legítimo de datos personales y sanitarios, confidencialidad y notificación de posibles brechas.
Dirección médica y responsables clínicos	Adaptar la formación a médicos, enfermería, diagnóstico y otros profesionales sanitarios, considerando la continuidad asistencial y la confidencialidad de los pacientes.
Administración y atención al paciente	Aplicar las normas de acceso, uso y divulgación de información personal y sanitaria en las tareas administrativas.
Responsables de departamento e instalación	Comunicar las políticas a sus equipos, comprobar la participación y reforzar las medidas aplicables al trabajo diario.
Jurídico y Cumplimiento, cuando exista esta función	Revisar las obligaciones normativas, contractuales y organizativas aplicables.

Auditoría Interna o función de control independiente	Revisar evidencias, comprobar el cumplimiento y comunicar deficiencias.
Todos los empleados y colaboradores	Leer las políticas aplicables, completar la formación, superar las evaluaciones y cumplir las normas establecidas.

Cuando ACME Healthcare no disponga de un departamento independiente, la Dirección deberá asignar formalmente esas responsabilidades a las funciones correspondientes.

4. Plan de implementación y difusión

Fase 1. Preparación y aprobación

Plazo: semanas 1 y 2.

Tareas:

1. Revisar y aprobar las políticas y procedimientos vigentes.
2. Identificar los departamentos y grupos de empleados afectados por cada política.
3. Preparar una matriz que relacione cada política con los puestos a los que afecta.
4. Designar a los responsables de formación y comunicación.
5. Establecer los canales oficiales para publicar documentos y resolver dudas.
6. Preparar los materiales formativos, cuestionarios y ejercicios prácticos.
7. Definir los indicadores de seguimiento y los objetivos de cumplimiento.

Responsables: Dirección, Seguridad de la Información, Recursos Humanos y responsables de departamento.

Evidencias: políticas aprobadas, matriz de destinatarios, calendario, materiales y asignación de responsabilidades.

Fase 2. Publicación y comunicación inicial

Plazo: semana 3.

Tareas:

1. Publicar las versiones aprobadas en una ubicación corporativa accesible y controlada, como la intranet.

2. Comunicar a los empleados la disponibilidad de las políticas mediante los canales corporativos.
3. Explicar el objetivo, el alcance, la fecha de entrada en vigor y las responsabilidades principales.
4. Solicitar confirmación de lectura y aceptación de las normas cuando corresponda.
5. Informar de cómo consultar dudas, solicitar permisos o notificar incidentes de seguridad.
6. Comunicar las políticas también al personal que no utilice habitualmente un ordenador, mediante sesiones presenciales, reuniones de equipo u otros canales accesibles.

Responsables: Seguridad de la Información, Recursos Humanos y responsables de instalación.

Evidencias: comunicación enviada, registro de publicación, confirmaciones de lectura y listado de destinatarios.

Fase 3. Formación general obligatoria

Plazo: semanas 3 y 4, y antes de conceder acceso cuando sea necesario.

Todo el personal recibirá formación general sobre:

- Responsabilidades individuales en materia de seguridad.
- Protección de información confidencial y datos de pacientes.
- Gestión segura de contraseñas y autenticación multifactor.
- Reconocimiento de phishing y otras técnicas de ingeniería social.
- Uso aceptable de dispositivos y sistemas corporativos.
- Bloqueo de sesiones y protección de dispositivos desatendidos.
- Identificación y comunicación de incidentes de seguridad.
- Consecuencias del incumplimiento de las políticas.

La formación podrá impartirse mediante módulos en línea, sesiones presenciales, reuniones de equipo o una combinación de estos métodos.

Responsables: Seguridad de la Información y Recursos Humanos, con apoyo de TI y de los responsables de departamento.

Evidencias: registros de participación, materiales utilizados y resultados de las evaluaciones.

Fase 4. Formación específica por responsabilidades

Plazo: semanas 4 a 6.

Además de la formación general, cada grupo recibirá contenidos adecuados a sus funciones.

- **TI y administradores de sistemas:** mínimo privilegio, gestión de cuentas, altas y bajas, revisión de permisos, MFA, acceso remoto seguro, registros, actualizaciones y configuración segura.
- **Profesionales sanitarios:** acceso justificado a historias clínicas, confidencialidad, uso seguro de sistemas clínicos y protección de información durante la atención al paciente.
- **Administración y atención al paciente:** verificación de identidad, acceso autorizado a datos, divulgación segura y prevención de errores de envío.
- **Dirección y responsables de departamento:** aprobación de accesos, segregación de funciones, responsabilidades de supervisión y gestión de excepciones.
- **Recursos Humanos:** comunicación de incorporaciones, cambios de puesto y bajas para facilitar la asignación o revocación oportuna de permisos.
- **Personal con acceso remoto o privilegiado:** requisitos adicionales de autenticación, protección de dispositivos y uso de conexiones autorizadas.
- **Personal temporal y terceros:** formación proporcional a los accesos y riesgos que impliquen sus actividades.

Responsables: Seguridad de la Información, TI, Recursos Humanos y responsables de las áreas correspondientes.

Evidencias: programas específicos, registros de asistencia y resultados por grupo profesional.

Fase 5. Evaluación del conocimiento

Plazo: al finalizar cada formación.

Cada participante deberá completar una evaluación adaptada a su puesto. Se utilizarán preguntas tipo test, escenarios prácticos o ejercicios de aplicación.

Se propone como criterio inicial obtener al menos un **80 % de respuestas correctas**. Para funciones críticas, como administración de sistemas o gestión de accesos privilegiados, podrán establecerse requisitos más exigentes.

Quienes no alcancen el resultado mínimo deberán recibir formación de refuerzo y repetir la evaluación. La asistencia o la confirmación de lectura, por sí solas, no se considerarán prueba suficiente de comprensión.

Responsables: Seguridad de la Información y responsables de formación.

Evidencias: puntuaciones, fecha de realización, necesidades de refuerzo y resultados posteriores.

Fase 6. Refuerzo y mejora continua

Plazo: continuo.

Tareas:

1. Enviar recordatorios periódicos sobre los riesgos más relevantes.
2. Incorporar mensajes breves de seguridad a reuniones de equipo.
3. Revisar los contenidos cuando cambien las políticas, los sistemas o los riesgos.
4. Ofrecer formación adicional tras incidentes, incumplimientos o evaluaciones deficientes.
5. Analizar las preguntas frecuentes y los errores detectados para mejorar los materiales.
6. Realizar revisiones periódicas de cumplimiento y presentar los resultados a la Dirección.

Responsables: Seguridad de la Información, Recursos Humanos, TI y responsables de departamento.

Evidencias: comunicaciones de refuerzo, versiones actualizadas de los materiales, resultados de revisiones y acciones correctivas.

5. Calendario resumido

Periodo	Actividad principal	Resultado esperado
Semanas 1–2	Aprobación, identificación de destinatarios y preparación de materiales	Plan aprobado y formación preparada

Semana 3	Publicación y comunicación de las políticas	Personal informado de las políticas aplicables
Semanas 3–4	Formación general	Personal formado en conceptos básicos
Semanas 4–6	Formación específica por puesto	Personal preparado para aplicar sus responsabilidades
Al finalizar cada módulo	Evaluación de conocimientos	Evidencia de comprensión y detección de necesidades
Semana 7	Revisión de participación y resultados	Informe inicial de cumplimiento
Trimestralmente	Seguimiento de indicadores y riesgos	Detección de deficiencias y acciones de mejora
Anualmente y ante cambios importantes	Revisión de políticas y formación	Contenidos actualizados

Los plazos son una propuesta inicial y deberán ajustarse a las necesidades operativas de las instalaciones, sin dejar sin formar a los grupos afectados.

6. Evaluación de la eficacia del plan

ACME Healthcare utilizará indicadores medibles para comprobar que las políticas no solo se han comunicado, sino que también se comprenden y aplican.

Indicador	Método de cálculo o comprobación	Objetivo inicial
Cobertura de formación	Personas que completan la formación / personas obligadas a realizarla × 100	≥ 95 % al cierre del periodo inicial
Tasa de aprobación	Participantes que superan la evaluación / participantes evaluados × 100	≥ 90 % tras las acciones de refuerzo

Confirmación de lectura	Personas que confirman la lectura / destinatarios × 100	100 % de los destinatarios identificados
Formación de refuerzo completada	Personas pendientes que completan el refuerzo / personas que lo necesitan × 100	100 %
Formación de nuevas incorporaciones	Nuevas incorporaciones formadas dentro del plazo interno / total de nuevas incorporaciones × 100	100 %
Incidencias relacionadas con errores humanos	Número, tipo y tendencia de incidentes relacionados con el incumplimiento de políticas	Tendencia descendente, analizada junto con la gravedad y la exposición
Acciones correctivas cerradas	Acciones cerradas dentro del plazo / acciones con plazo vencido o exigible × 100	≥ 90 % dentro del plazo establecido

Los objetivos anteriores son metas propuestas, no resultados ya alcanzados. Deberán revisarse tras establecer una línea base.

La Dirección y el Responsable de Seguridad de la Información revisarán los resultados al menos trimestralmente. Los resultados se desglosarán por departamento, instalación y tipo de formación para identificar grupos que necesiten apoyo adicional.

6.1 Métodos para comprobar la comprensión práctica

Además de los cuestionarios, ACME Healthcare podrá utilizar:

- **Escenarios prácticos:** por ejemplo, determinar cómo actuar ante una solicitud de acceso no autorizada o un correo que contiene información clínica enviado al destinatario equivocado.
- **Ejercicios de control de acceso:** verificar que el personal responsable distingue entre permisos de lectura, modificación y administración.
- **Simulaciones de phishing autorizadas:** medir la capacidad de reconocer mensajes sospechosos y notificar su recepción.

- **Revisiones de cumplimiento:** comprobar, mediante evidencias autorizadas, si los procedimientos se aplican en la práctica.
- **Entrevistas o preguntas breves:** confirmar que los empleados conocen el canal de notificación de incidentes y saben a quién acudir en caso de duda.

Estas actividades deberán diseñarse de forma proporcional al puesto y sin poner en riesgo datos reales de pacientes ni interrumpir la asistencia sanitaria.

7. Gestión de incumplimientos y acciones correctivas

Cuando una persona no complete la formación obligatoria, no supere la evaluación o incumpla una política, se aplicarán las siguientes medidas según la gravedad:

1. Notificar la deficiencia al empleado y al responsable correspondiente.
2. Proporcionar formación adicional y un plazo para completar la evaluación.
3. Documentar el resultado y las medidas correctivas.
4. Si existe riesgo inmediato, aplicar medidas temporales de protección, incluida la limitación de accesos cuando esté justificada y autorizada.
5. Escalar los incumplimientos graves o reiterados a Seguridad de la Información, Recursos Humanos y, cuando proceda, a la Dirección.
6. Aplicar las medidas disciplinarias o contractuales que correspondan conforme a las normas internas y la legislación aplicable.

La formación y la gestión de incumplimientos deberán tratarse de forma justa, coherente y documentada.

8. Registros y conservación de evidencias

ACME Healthcare mantendrá registros de:

- Políticas y materiales publicados, con sus versiones.
- Comunicaciones y destinatarios.
- Formación completada y asistencia.
- Confirmaciones de lectura, cuando procedan.
- Resultados de las evaluaciones.
- Acciones de refuerzo y reevaluaciones.
- Indicadores, informes de seguimiento y acciones correctivas.

El acceso a estos registros se limitará a las personas autorizadas. Su conservación y eliminación se ajustarán a las políticas internas y a los requisitos legales aplicables.

9. Aprobación y revisión

La Dirección deberá aprobar este plan antes de su implantación. El Responsable de Seguridad de la Información coordinará su ejecución y propondrá las actualizaciones necesarias.

El plan se revisará al menos anualmente y cuando se produzcan cambios importantes en la organización, las políticas, los sistemas, los riesgos o las obligaciones legales.

Aprobado por	Dirección de ACME Healthcare
Responsable de ejecución	Responsable de Seguridad de la Información
Fecha de aprobación	Pendiente
Próxima revisión	Un año después de la aprobación, o antes si se producen cambios relevantes